

EC2 Instance Metadata Service

IMDS v1 e v2 — Diferenciais, Segurança e Uso Prático

AWS Certified Developer Associate

Instrutor: Marlon Anesi

O que é o Instance Metadata Service?

Endpoint HTTP especial disponível APENAS de dentro de uma instância EC2:

<http://169.254.169.254/latest/meta-data/>

O que você consegue com o IMDS:

Identidade da Instância

- instance-id
- instance-type
- ami-id
- placement/region
- placement/availability-zone

Rede e Conectividade

- local-ipv4 (IP privado)
- public-ipv4 (IP público)
- mac
- network/interfaces/
- hostname

Credenciais IAM

- iam/security-credentials/
- Token temporário (access key)
- Secret access key
- Session token
- Expiração das credenciais

IMDSv1 x IMDSv2 — A Diferença que Cai na Prova



IMDSv1 — Método Legado

- Acesso direto via GET HTTP
- Sem autenticação ou token
- Qualquer processo dentro da instância acessa
- Vulnerável a SSRF (Server-Side Request Forgery)
- Ainda disponível por compatibilidade
- Não recomendado para produção

```
# IMDSv1 - GET direto
curl
http://169.254.169.254/latest/meta-data/instance-id
```



IMDSv2 — Método Recomendado

- Requer token de sessão (TTL 1s - 21600s)
- 2 requisições: obter token + usar token
- Token com cabeçalho X-aws-ec2-metadata-token
- Protege contra ataques SSRF
- Pode ser obrigatório (IMDSv2 required)
- Recomendado pela AWS para todos os casos novos

```
# IMDSv2 - Passo 1: obter token
TOKEN=$(curl -X PUT ...ttl-seconds=21600 ...)
# Passo 2: usar token
curl -H "X-aws-ec2-metadata-token: $TOKEN" ...
```

Ataque SSRF (Server-Side Request Forgery): o atacante faz a aplicação fazer uma requisição interna para `http://169.254.169.254` e lê as credenciais IAM da instância. O IMDSv2 mitiga isso exigindo o cabeçalho PUT para obter o token, que uma requisição SSRF simples não consegue forjar.

IMDS na Prática: Exemplos e Casos de Uso

Exemplo Completo IMDSv2 (recomendado):

```
# Passo 1: Obter token de sessão (TTL de 6 horas = 21600 segundos)
TOKEN=$(curl -s -X PUT \
  http://169.254.169.254/latest/api/token \
  -H 'X-aws-ec2-metadata-token-ttl-seconds: 21600')

# Passo 2: Usar o token para obter metadados
INSTANCE_ID=$(curl -s http://169.254.169.254/latest/meta-data/instance-id \
  -H "X-aws-ec2-metadata-token: $TOKEN")
```

Principais casos de uso para desenvolvedores:

Descobrir a região dinamicamente

Leia placement/region em vez de codificar a região no código. A aplicação se adapta automaticamente ao ambiente.

Obter o IP interno

Leia local-ipv4 para registrar a instância num load balancer ou service registry sem hardcode de IPs.

Credenciais IAM temporárias

SDKs AWS buscam credenciais automaticamente via IMDS. Você nunca deve hardcodar access keys no código — use roles.

Pontos-chave para a Prova

1. O que é e para que serve o IMDS

Endpoint interno 169.254.169.254 — acessível APENAS de dentro da instância. Fornece: instance-id, tipo, região, IP e credenciais IAM temporárias.

2. Diferença crítica: IMDSv1 x IMDSv2

v1: GET direto, sem token, vulnerável a SSRF | **v2:** token de sessão obrigatório via PUT, protegido contra SSRF

3. Credenciais IAM via IMDS — regra de ouro

Os SDKs AWS buscam credenciais automaticamente no IMDS via IAM Role. NUNCA hardcode access keys no código. Use IAM Role na instância e deixe o SDK resolver.

LEMBRE-SE: Se menciona 'metadados da instância' ou '169.254.169.254' > pense IMDS! Se a questão pede o método seguro contra SSRF > IMDSv2 com token PUT. Se menciona 'credenciais automaticas no EC2' > IAM Role via IMDS!